

Enumeracion de SMTP

Objetivos de aprendizaje

Identificar la superficie, explicar la causa, diseñar una confirmación mínima, interpretar evidencia y proponer una mitigación causal.

Prerrequisitos

Flujo source-transformación-validación-sink, parsers, permisos y metodología de hipótesis. Revisa los prerrequisitos declarados en los metadatos.

Fundamentos técnicos

SMTP (puerto 25, o 587/465) es el protocolo de envío de correo. Algunos servidores mal configurados responden a los comandos VRFY (verifica si un usuario existe) o EXPN (expande una lista de distribución), lo que te deja confirmar usuarios validos del dominio sin autenticarte. El banner tambien suele filtrar el software y version del MTA.

VRFY/EXPN son comandos legitimos del protocolo SMTP pensados para diagnostico, pero dejarlos activos sin restriccion permite enumerar cuentas de correo validas (que a menudo son tambien cuentas del sistema o del dominio). Es la misma logica de fuga de informacion que RID brute en smb-enum.

Modelo mental

Entrada controlada -> transformaciones -> validación -> componente final
-> sink -> efecto observable -> decisión

El paso crítico es demostrar qué componente consume el valor y con qué identidad o privilegios.

Superficie de ataque

Cuando el recon muestra el puerto 25 (o 587/465) abierto. Sirve tanto para sacar usuarios como para entender que servidor de correo corre.

Cómo identificarla

- Puerto 25/587/465 abierto en el escaneo.
- El banner de conexion revela el software MTA y su version.
- VRFY responde con codigos distintos segun si el usuario existe o no.

Preguntas que debo hacerme

- ¿Qué dato controlo exactamente y en qué formato viaja?
- ¿Qué transformaciones y normalizaciones ocurren antes del sink?
- ¿Qué identidad ejecuta la operación y qué permisos tiene?
- ¿Qué otra explicación produciría la misma señal?
- ¿Cuál es la prueba de menor riesgo que separa ambas explicaciones?

Prueba mínima

Conecta por SMTP y prueba VRFY con un nombre de usuario probable (root, admin, un nombre visto en otra fuente).

Evidencia esperada: Un codigo 250/252 (usuario existe) frente a 550 (no existe) te deja distinguir usuarios validos probando varios nombres.

Construcción progresiva del payload

1. Reproduce una entrada válida.
2. Aísla un único valor controlable.

3. Define la primitiva mínima indicada por la fuente.
4. Predice resultado y control negativo.
5. Aplica una sola adaptación cuando haya evidencia de restricción.
6. Confirma de forma reproducible antes de ampliar impacto.

Capa 1: prueba documentada

`nc -nv $IP 25`

Objetivo y contexto: Conecta directamente por SMTP para leer el banner (revela software/version) e interactuar a mano con VRFY/EXPN.

Resultado esperado: Un banner tipo '220 mail.corp.local ESMTP Postfix'. Desde esta sesión, escribe VRFY usuario y observa el código de respuesta.

Anatomía de los payloads

La primera prueba es `nc -nv $IP 25`. Separa sus delimitadores, operadores, opciones, operandos y variables; algunos elementos no estarán presentes según el contexto. Las comillas, barras y separadores pertenecen a una capa concreta. Usa la explicación de cada capa para determinar qué símbolo altera sintaxis y cuál transporta datos.

Variaciones según el contexto

No traslades una prueba entre sistemas operativos, motores, frameworks o versiones sin revisar sintaxis y comportamiento. Conserva la primitiva y vuelve a serializarla para el parser real.

Filtros y bypasses

No existe un bypass universal. Registra la forma enviada, la forma decodificada, la comparación, la normalización y la forma consumida. Una adaptación es válida solo si demuestra una discrepancia concreta; si la validación ocurre sobre la forma canónica y expresa la propiedad correcta, la variante no debe funcionar.

Evidencias de confirmación

Un código 250/252 (usuario existe) frente a 550 (no existe) te deja distinguir usuarios válidos probando varios nombres.

Usa además una entrada inocua y un control negativo. No confundas reflexión, error genérico o demora aislada con confirmación.

Escalado de impacto

- Conecta y observa el banner: a veces ya revela el software y version.
- Prueba VRFY con nombres candidatos (usuarios ya vistos en otras fuentes, nombres comunes).
- Si VRFY está desactivado, prueba EXPN sobre listas de distribución conocidas o comunes.
- Los usuarios confirmados alimentan spraying (fuerza-bruta-online) contra otros servicios del objetivo.

Amplía únicamente dentro del laboratorio y cuando cada salto aporte una capacidad nueva demostrable.

Errores frecuentes

- El servidor tiene VRFY/EXPN desactivados (respuesta 'not implemented' o similar) y no hay otra vía de enumerar usuarios por SMTP.
- El puerto pertenece a un relay externo (no al servidor objetivo) sin relación con el dominio que atacas.
- Ejecutar la prueba sin adaptar variables ni versión.
- Cambiar varias capas a la vez.
- Omitir el control negativo o no guardar evidencia.

Diagnóstico de payloads fallidos

Síntoma	Posible causa	Prueba de diagnóstico	Adaptación
Rechazo inmediato	Formato o precondition	Repetir entrada válida	Corregir transporte
Sin diferencia	Entrada ignorada o canal ciego	Marcador y control negativo	Buscar evidencia adecuada
Error del componente	Contexto o versión	Reducir a prueba mínima	Consultar manual detectado
Resultado parcial	Permisos/restricción	Comprobar identidad y alcance	Reducir primitiva

Mitigaciones

Eliminar el dato controlable del sink cuando sea posible; usar APIs estructuradas, allowlists sobre valores canónicos, privilegio mínimo, autorización en servidor y registros que permitan detectar abuso. La defensa concreta debe impedir la causa explicada en Fundamentos técnicos.

Relación con pentesting y certificaciones

Se espera reconocer la señal, justificar la prueba elegida, adaptar variables, interpretar salida y documentar impacto y mitigación. La puntuación debe premiar razonamiento y evidencia, no memoria literal.

Caso guiado

Parte de una señal de la lista anterior. Escribe observación e hipótesis, ejecuta la prueba mínima, compara con el control y clasifica el resultado como no confirmado, indicio o confirmación. Solo entonces sigue los pasos de escalado relevantes.

Caso de adaptación

Si la prueba básica falla, no cambies caracteres al azar. Comprueba primero transporte, parser, versión, permisos y canal de evidencia. Diseña una segunda prueba que discrimine entre las dos causas más probables.

Ejercicios

1. Señala source, transformaciones y sink en el caso guiado.
2. Explica qué evidencia refutaría la hipótesis.
3. Descompón la primera prueba documentada por opciones y argumentos.
4. Propón un control negativo y una mitigación causal.

Resumen

El servidor de correo a veces confirma si un usuario existe (VRFY/EXPN) o filtra software en el banner. La técnica queda confirmada solo cuando una prueba mínima produce la evidencia prevista y descarta explicaciones alternativas.

Chuleta operativa

1. Confirmar alcance y condiciones.
2. Identificar entrada, componente y permisos.
3. Ejecutar prueba mínima y control.
4. Interpretar señal antes de escalar.
5. Guardar evidencia y mitigación.

Referencias

- [Concepto fuente de THM Fieldbook \(smtp-enum\)](#)
- [Referencia técnica externa](#)

Navegación

Anterior: [Construcción de payloads](#). Índice: [curso](#). Ejercicios y chuleta se enlazarán desde la matriz de trazabilidad.